

ENTERPRISE AI KNOWLEDGE ASSISTANT

Enterprise Project Management Toolkit

AI Risk Evaluation & Safety Case

Responsible AI Assessment – Enterprise AI Knowledge Assistant

Document Title	AI Risk Evaluation & Safety Case
Project Name	Enterprise AI Knowledge Assistant (EAIKA)
Author	Information Security / Engineering
Version	1
Status	Approved
Date	4-Jul-26

1. Purpose

This document assesses the risks specific to deploying a Retrieval-Augmented Generation (RAG) system in an enterprise setting and describes the safeguards built into EAIKA to manage those risks. It supports Information Security review and ongoing AI governance for the platform.

2. System Description (for Risk Context)

EAIKA retrieves relevant chunks of enterprise documents from a local ChromaDB vector store and uses a locally hosted large language model (Qwen2.5, served via Ollama) to synthesize a natural-language answer grounded in those chunks. All inference occurs within the organization’s-controlled environment; no document content or query is sent to an external AI provider.

3. AI Risk Categories & Assessment

Risk Category	Description	Likelihood	Impact	Mitigation
Hallucination / Unsupported Answers	The LLM may generate a plausible-sounding answer not actually supported by the retrieved source content.	Medium	High	Prompting constrains the model to answer only from retrieved context; mandatory source citation lets users verify every answer; UAT includes explicit accuracy sampling.
Incomplete Retrieval	Relevant information exists in the knowledge base but is not retrieved due to chunking or embedding limitations.	Medium	Medium	Chunk size/overlap tuning during build; retrieval quality monitored via user feedback and periodic sampling; “no relevant information found” fallback rather than guessing.
Data Confidentiality Exposure	Sensitive document content could be exposed outside intended audiences.	Low	High	100% local processing - no external AI API calls; administrator-only upload/rebuild functions; storage on encrypted volumes; access behind organizational SSO/reverse proxy.
Outdated / Conflicting Source Documents	The knowledge base may contain superseded documents, producing answers based on stale information.	Medium	Medium	Document inventory and knowledge base statistics visible to administrators; recommended process for retiring outdated documents before rebuilding.
Over-Reliance on AI Output	Users may treat AI-generated answers as authoritative without verifying the cited source.	Medium	Medium	Source Transparency feature is mandatory in the UI; user training emphasizes verifying citations, especially for high-stakes decisions.
Model / Service Availability	The local Ollama service or LLM host becomes unavailable, halting answer generation.	Low	Medium	Monitoring and alerting per the Enterprise Readiness & SLA; documented recovery runbook.
Bias / Fairness in Generated Answers	Answers could reflect skew present in the underlying documents or model training data.	Low	Low-Medium	Scope limited to enterprise-authored documents (not open-ended generation); periodic review of flagged answers during pilot.
Prompt Injection via Uploaded Documents	A malicious or malformed document could attempt to manipulate model behavior through embedded instructions.	Low	Medium	Document content is treated strictly as retrieval context, not as system instructions; input sanitization during ingestion; administrator-controlled uploads only.

4. Safety Case Summary

The primary safety argument for EAIKA rests on three pillars:

- 1) local-only processing eliminates the risk of sensitive data leaving the organization.

- 2) mandatory source citation ensures every answer is independently verifiable, mitigating the impact of any hallucination.
- 3) administrator-controlled ingestion limits the attack surface for malicious document content compared with an open, self-service upload model.

5. Human Oversight & Escalation

- Users are instructed to treat AI-generated answers as a starting point for verification, not a final authority, particularly for decisions with material business impact.
- A feedback mechanism (captured during UAT and post-launch) allows users to flag inaccurate or unhelpful answers for review by the engineering/product team.
- Repeated inaccuracies on a given topic trigger a review of the underlying source documents and retrieval configuration rather than a change to the model alone.

6. Residual Risk Statement

After the mitigations above, the residual risk of an isolated inaccurate answer remains present, as with any AI-generated content, but is substantially reduced by mandatory source citation and the local-only data handling model. Residual risk is considered acceptable for the Phase 1 pilot scope (Project & Program Management knowledge), subject to ongoing monitoring during the stabilization period.

7. Recommendations Prior to Domain Expansion

- Re-assess this Safety Case before extending EAIKA into higher-sensitivity domains such as Healthcare, Finance & Compliance, or Legal, given the increased regulatory and confidentiality stakes.
- Introduce role-based access control and audit logging ahead of any expansion beyond the current pilot audience.

8. Approval

Reviewer	Role	Decision
Information Security Officer	Risk & Compliance Review	Approved
Engineering Lead	Technical Mitigation Review	Approved
Product Owner	Business Risk Acceptance	Approved